

RetrackThis: what to fix next, and in what order

September 20, 2026 · Follows the review of commits `7669afe..43732ea` · Finding IDs (D-n) point into *D-critic-consolidated.md*, which has the file, line, and quoted code for each one

The short version. About half the Day-1 list is genuinely closed, and the parts that held were attacked twice and survived. Three things need attention today: the deadline cap shipped as 3 days instead of 7 and rejects the form's own default, the money engine underneath the new "End gig and pay" flow is still the September 4 one (no lock, no refund path) and now runs inside the public jobs page, and the "hide the master until award" feature doesn't hide anything. Section 2 is fourteen one-line changes that close or shrink most of the HIGH items in one sitting. Section 3 is the one real design change, and it should ride on the capture-on-post work you already want to do.

1. What held: leave these alone

- ✓ **Takes listing** requires a session and creator-or-admin. Anonymous gets 401, other users get 403. Public job list carries only a count.
- ✓ **Buyer is not seller** lives in `lib/jobActions.ts`, so provisional pick, finalize, and the sweep all inherit it. Submit-to-own-job is refused before the replacement branch, so replacement inherits it too.
- ✓ **Upload signing** requires a session and prefixes the path with the user id.
- ✓ **RLS migration** covers all five tables and `_prisma_migrations`, as a migration. Right layer.
- ✓ **Retry safety:** capture checks the intent status first; transfer checks `transfers.list` by `transfer_group` before creating. A lost response no longer double-pays.
- ✓ **Price and deadline can't be edited** after posting. PATCH rejects payment keys and has no deadline field.
- ✓ **Webhook signatures, Connect account binding, admin confirmed-email check, PKCE on the Google callback.** All held.

2. Today: fourteen one-line changes

None of these is a design change. Each is a guard clause, a constant, a helper call, or a migration. Ship as one PR. Items marked `payment flow` touch the README's protected section and get flagged to all three founders. `reopens` means a Day-1 item you listed as done that needs another pass.

☐ 1. Make the deadline cap one number, used everywhere. payment flow reopens #8

What's wrong: `app/api/jobs/route.ts` has two checks. The first rejects anything where deadline plus the 72-hour grace exceeds 6 days, which caps real deadlines at 3 days. The second (7 days via `MAX_DEADLINE_DAYS`) can never fire. The form's default is rejected. **Change:** set `MAX_DEADLINE_DAYS = 3`, use it in the form default, form validation, hint text, and the one server check; delete the dead branch; add about 5 minutes of server-side slack for clock skew. **Verify:** post a job with the default deadline on staging; it must succeed. Closes D-10.

☐ 2. Stop the duplicate "3 days left" email on every new job.

What's wrong: a 3-day job is already inside the 3-day reminder window at creation, so the reminder fires seconds after the "new job" alert. **Change:** in the reminder sweep, skip jobs created in the last 24 hours, or whose whole window is 3 days or less. **Verify:** post a job; musicians get one email, not two. Closes the email half of D-10.

☐ 3. Fix the redirect helper and use it everywhere. reopens #5

What's wrong: `lib/safeRedirect.ts` lets `/\t/evil.com` (tab, CR, or LF after the first slash) through; browsers strip the control character and land on `evil.com`. And `app/auth/callback/route.ts` has its own weaker copy that lets `/\evil.com` through. **Change:** canonicalise with `new URL(next, origin)`, reject when `u.origin !== origin` or the string contains any character in `[\x00-\x1f]`; call the helper from the callback too. **Verify:** the nine strings listed in D-16 all land on `/producers`. Closes D-16.

☐ 4. Put a ceiling and an integer check on price. payment flow

What's wrong: the server accepts any number at or above 100 cents, so the two-account cash-out has no limit. **Change:** `Number.isInteger(priceCents) && priceCents <= MAX_PRICE_CENTS` server-side, with the founders picking the number (the slider max is the obvious value). **Verify:** a POST with 999999999 gets 400. Shrinks D-1; part of D-7.

☐ 5. Stop returning the musician's payout email to the producer; notify admins on every manual payout.

What's wrong: `select-winner` returns `payoutEmail` and `payoutAccountName` in its JSON. No admin is told when a job lands in `pending_manual_payout`, so nothing ever moves it. **Change:** strip those fields from the response; email the admin allowlist whenever that status is written. **Verify:** award a PayPal musician on staging; the response has no email, the admins get one. First half of D-8.

☐ 6. Stop reconfiguring the bucket on every upload; drop octet-stream. reopens #2

What's wrong: `app/api/uploads/sign/route.ts` calls `updateBucket({ public: true, ... })` on every request and the MIME allowlist includes `application/octet-stream`, which is any file. Anyone who makes the bucket private in the dashboard is undone by the next upload. **Change:** delete the `updateBucket` call and the `public: true` in `ensureAudioBucket`; configure the bucket once, out of band; remove octet-stream. **Verify:** flip the bucket private in the dashboard, mint an upload, confirm it's still private. Closes D-14; prerequisite for section 4.

☐ **7. Make RLS cover the next table, not just these five.**

What's wrong: the migration enables RLS and revokes grants on today's tables only. The next `prisma migrate` that adds a table exposes it to the anon key again. **Change:** a new migration with `ALTER DEFAULT PRIVILEGES IN SCHEMA public REVOKE ALL ON TABLES FROM anon, authenticated (and sequences); add directUrl to schema.prisma` so migrations don't go through the transaction pooler; turn the Data API off in Supabase if nothing uses it (nothing in the app does). **Verify:** create a throwaway table in staging; the anon-key curl against it returns nothing. Closes D-17.

☐ **8. Make the seed guard an allowlist and fail loud.** reopens #7

What's wrong: `prisma/scriptGuard.js` is a hostname denylist that misses Supabase's direct host (`db.<ref>.supabase.co`), so a normal `.env.local` slips it; `seed.js` loads `.env.local` before the guard runs; `testpass123` is still the fallback. **Change:** allow only `localhost` and hosts you name; read `ALLOW_PROD_SCRIPTS` from the real environment only; throw when `SEED_TEST_PASSWORD` is unset. **Verify:** run the seed with a direct-host URL and no override; it must refuse. Closes D-18.

☐ **9. Finish the webhook guards.** reopens #10

What's wrong: `canceled` and `payment_failed` have no allowed-from list, writes are still find-then-update, `stripePaymentIntentId` has no unique index, and onboarding can still create a second Connect account. **Change:** `updateMany` with an allowed-from list on all four events; `@unique` on the intent id; `updateMany` where `stripeAccountId: null` in onboard. **Verify:** replay a `canceled` event against a `transferred` payment; status must not change. Closes D-6.

☐ **10. One error helper, used on every route.** reopens #11

What's wrong: only `uploads/sign` was sanitized. `select-winner`, `connect/onboard`, `connect/dashboard`, `uploads/preview`, and `jobs` POST still return raw Stripe, Prisma, Supabase, and ffmpeg text. **Change:** one `clientError(err)` helper that logs the detail and returns a fixed message; map Stripe `decline_code` to a short fixed set. **Verify:** force a Stripe error on staging; the response is generic. Part of D-20.

☐ **11. One admin predicate.**

What's wrong: the confirmed-email admin check is written twice, in `lib/admin.ts` and `app/api/auth/me/route.ts`. **Change:** `me/route.ts` calls the function in `lib/admin.ts`. Part of D-19.

☐ **12. Repo hygiene.**

Change: add `tsconfig.tsbuildinfo` to `.gitignore` and remove it from the repo (850 KB build cache); remove `fluent-ffmpeg` from `package.json` (nothing imports it); if previews stay, add `outputFileTracingIncludes` for the `ffmpeg-static` binary so it actually ships to Vercel. Part of D-27 and D-11.

☐ **13. A confirm step on every pay button.**

What's wrong: one un-confirmed click captures and transfers, and after the deadline every button on the job is a pay button. **Change:** a confirm dialog naming the musician and the amount before "End gig and pay" and before any post-deadline finalize. Closes D-9.

☐ **14. Claim before send on the reminder sweeps.**

What's wrong: both sweeps mark the job after sending, so two concurrent page loads send twice; the admin re-send has no "already sent" check. **Change:** `updateMany` that sets the sent timestamp where it's null, and only send when that update counted 1. Closes D-23.

3. Week 1: the escrow state machine, one reviewed change payment flow

This is the September 4 root cause and it hasn't moved. Do it as one coherent change, reviewed as a unit, and make it the vehicle for capture-on-post rather than a separate project. The founders' decisions in section 6 come first.

- ☐ **Atomic claim before any Stripe call (D-3).** `db.job.updateMany({ where: { id, status: "OPEN" }, data: { status: "AWARDING" } })` and abort unless `count === 1`. Same for cancel with `CANCELLING`. Persist `stripeChargeId`, `stripeTransferId`, and the paid `takeId` in the same write as the status, and refuse to record a different winner.
- ☐ **Cancel that can refund (D-2).** In `cancelJobAndRefund`, retrieve the intent first. `requires_capture`: cancel the hold. `succeeded`: `refunds.create` and write `refunded`, or refuse and flag to admin. Never write `cancelled` over a succeeded intent. There is no refund call anywhere in the app today.
- ☐ **Sweeps out of the public page (D-4, D-5, D-23).** A Vercel Cron runs all four sweeps with bounded batches and the same atomic claim. Remove every sweep from `GET /api/jobs` and `GET /api/admin/jobs`. Handle `payment_intent.canceled` by closing the job in the webhook. Takes POST requires `payment.status === "authorized"`.
- ☐ **Idempotency and ordering (D-7).** Idempotency keys and `metadata` on every Stripe mutation. Validate everything before creating the intent; cancel the intent in a `catch` around `db.job.create`.
- ☐ **A real ledger for manual payouts (D-8).** A `Payout` table (job, take, musician, provider, destination snapshot, amount, status, paidAt, paidBy, external ref) written in the award transaction; an admin-only "mark paid"; block `payouts/alt` edits while a payout is pending; alt destinations need founder verification before the takes gate passes.
- ☐ **Business controls against the two-account cash-out (D-1).** A Stripe Customer per creator so Radar can score; a transfer delay for first-time recipients; a `charge.dispute.created` handler; Radar rules. Capture-on-post rides on this foundation.
- ☐ **Make `Payment.status` a Prisma enum.**

4. Week 2: storage and previews (product decision first, then design)

Today: the bucket is public, the preview is a full-length 192 kbps MP3, its path is the master's path plus `.preview.mp3`, the transcoder can be pointed at anyone's file, and on Vercel it most likely fails and hands out the master. Fix number 6 above stops the bucket being re-published; this section makes it private.

- ☐ **Decide what a producer may hear before award** (founders): a clip of N seconds, a watermarked or low-bitrate render, or the full take. Full-length previews on a free-cancel product are the giveaway problem. Closes the design half of D-11.
- ☐ **Private bucket, paths not URLs, signed reads.** Store object paths; mint short-lived signed read URLs from the takes endpoint under the same creator-or-admin rule. Every link ever issued stops being a permanent key. Closes D-11 and the September 4 E-3.
- ☐ **Previews under unrelated keys, generated off the request path.** `preview/<uuid>.mp3` with no relation to the master; generate asynchronously (cron or queue); fail closed: if no preview exists, return neither URL and show "processing." For MIDI-only takes, don't expose `audioFileUrl`. Closes D-11 fail-open and D-13.
- ☐ **Owner-scoped prefix; derive the preview server-side.** Require `fileUrl` to start with `<prefix>/<kind>/<sessionId>/` for the kind being submitted; ignore the client's `previewUrl` entirely. Closes D-12.
- ☐ **Delete old objects on take replacement** (and their preview); bind the paid content to what was auditioned (a content hash or the file id at pick time). Closes D-15.

5. Weeks 2 to 3: abuse, admin, and the loose ends

- ☐ **Rate limiting** per user and per IP on jobs POST, takes POST, upload sign, preview, and payouts/alt; a cap on take replacements. D-20.
- ☐ **Admin audit trail.** An `AdminAction` row for every admin mutation; refuse `reset-payouts` on a provisional winner; make `force` a typed confirmation. D-21.
- ☐ **Demo Mode branch: don't merge as-is.** It makes every visitor a signed-in user on one build-time env var with no production kill switch and ships an unguarded wipe script. Before merging: a runtime `VERCEL_ENV !== "production"` guard, `scriptGuard` in `seed-demo.js`, verified env scoping, Deployment Protection on previews. D-22.
- ☐ **Public job DTO** instead of the full row; recovery-only reset form; security headers; reverse the September 5 opt-out flip where it can be recovered. D-26, D-25, D-28.

6. Decisions to bring to the founders' call

- ☐ **Price ceiling** number for fix 4.
- ☐ **Cancellation policy under capture-on-post.** Stripe keeps its fee on refunds (about 3% plus 30 cents). A short free-cancel window then refund minus fee, or the fee absorbed as cost of doing business. Decided and written down before section 3 starts.
- ☐ **Preview policy** for section 4: clip length, watermark, or full take.
- ☐ **Capture-on-post: yes, and as the vehicle for section 3.** The reviewer's recommendation, with reasons, is in *REVIEW-SUMMARY.md*. The hosted Checkout page is optional; the existing Payment Element with automatic capture gets the same result. Skip BNPL in the first version.
- ☐ **Demo Mode** conditions above.

7. Tests: the minimum that would have caught this batch

There are still zero tests. None of the Day-1 guards has a regression detector, and the 3-versus-7-day mistake is exactly what one test catches before it ships. The minimum set, in whatever runner you prefer (Vitest fits this stack):

- ☐ The deadline boundary: default form value accepted, one day over rejected.
- ☐ `safeInternalPath` against the nine strings in D-16.
- ☐ Buyer is not seller on all three paths.
- ☐ Storage prefix with the owner segment.
- ☐ Webhook allowed-from lists on all four events.
- ☐ `cancelJobAndRefund` against a succeeded intent (Stripe mocked).

8. Runtime checks: one line back on each

Exact queries, commands, and click paths are in the *Runtime checks* section of *D-critic-consolidated.md*.

#	Question	How	Send back
1	Is production running this code, and is the 3-day cap live?	The SQL in D lists jobs since Sept 20 with their deadline length and reminder timestamp. Then post a job on staging with the default deadline.	Any job over 3 days? Reminder within minutes of creation? Default post accepted or 400?
2	The keyboard job and the violin recovery	The SQL in D lists pre-Sept-20 OPEN jobs with their intent id; retrieve each in Stripe.	Hold alive (finalize now) or canceled (repost)?

#	Question	How	Send back
3	RLS actually applied in production	Migration row present; anon-key curl against <code>User</code> ; Advisors panel empty; Data API toggle.	Curl result; Data API on or off
4	Supabase Auth toggles and the redirect	Confirm email ON, Secure email change ON, no <code>example.com</code> users, Google provider and redirect allowlist. Then sign in with <code>?next=/%09/evil.com</code> .	Toggles; landed on <code>evil.com</code> or <code>/producers?</code>
5	Does ffmpeg run on Vercel?	Count takes with a <code>.preview.mp3</code> URL versus null; check function logs for the preview route.	Any previews ever generated?
6	Bucket state and the master-derivation bypass	Storage settings: public, MIME list, size limit. Then take a preview URL, swap <code>.preview.mp3</code> for <code>.wav</code> , open in a private window.	Downloads or 404?
7	Stripe transfer cap and settings	Test mode: capture \$10, transfer \$9, second \$9 must fail. Webhook events, connected-accounts toggle, Radar rules.	Second transfer failed? Radar rules present?
8	Vercel Fluid Compute and the pooler	Project settings: Fluid Compute on? If so, <code>connection_limit=1</code> is a one-query-at-a-time ceiling per instance; watch for Prisma P2024 in logs.	Fluid on or off; any P2024?

9. When this lands

Send the PR batch for section 2 first; it gets the same verify, refute, critic pass on the diff before merge. Section 3 goes as one PR with the founders' decisions written into its description. Update `README.md` lines 27 to 40 and `HANDOFF.md` to match whatever ships; the README section exists so payment-flow changes get flagged, and it's been changed three times without one.